

19 — Sources, References & Authority Basis

Part XI — Reference. The authoritative basis for this handbook. Standards evolve — always verify version-specific details against the primary source before a production decision. **Content baseline: June 2026.**

How this handbook is grounded

This handbook synthesizes **official standards, regulatory texts, primary project documentation, and recognized practitioner literature**. It deliberately favors:

1. **Official standards bodies & regulators** (NIST, EU, ISO, OWASP, CNCF).
2. **Primary project documentation** (Kubernetes, Argo, Flagger, Helm, OpenTelemetry, Sigstore).
3. **Recognized practitioner works** by widely-cited authors and organizations.

Where practices vary across the industry, the handbook presents a defensible default and notes trade-offs.

Security

- **OWASP Top 10 for LLM Applications** — the authoritative catalog of LLM application risks (LLM01–LLM10). OWASP GenAI Security Project. → <https://genai.owasp.org/>
- **OWASP Top 10 for LLM Applications (project & PDF releases)** → <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
- **MITRE ATLAS** — Adversarial Threat Landscape for AI Systems (adversarial ML tactics/techniques). → <https://atlas.mitre.org/>
- **Microsoft STRIDE** threat-modeling methodology; **OWASP Threat Modeling** → https://owasp.org/www-community/Threat_Modeling
- **NIST SP 800-53** — security & privacy controls (control families referenced by security architecture).
- **OWASP Application Security Verification Standard (ASVS)** — baseline AppSec controls.

Governance, risk & compliance

- **NIST AI Risk Management Framework (AI RMF 1.0)** — Govern/Map/Measure/Manage. → <https://www.nist.gov/itl/ai-risk-management-framework>
- **NIST AI 600-1 — Generative AI Profile** — GenAI-specific risks and actions. → <https://doi.org/10.6028/NIST.AI.600-1>
- **EU Artificial Intelligence Act** — Regulation (EU) 2024/1689; risk tiers, high-risk & GPAI obligations. → <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>
- **ISO/IEC 42001** — AI management system (certifiable).
- **ISO/IEC 23894** — AI risk management guidance.

- **ISO/IEC 27001** — information security management.
- **OECD AI Principles** → <https://oecd.ai/en/ai-principles>

Observability

- **OpenTelemetry — Generative AI semantic conventions** (`gen_ai.*` attributes & metrics). → <https://opentelemetry.io/docs/specs/semconv/gen-ai/>
- **OpenTelemetry project** (CNCF). → <https://opentelemetry.io/>
- **Google SRE Book & SRE Workbook** — SLIs/SLOs, error budgets, runbooks, on-call. → <https://sre.google/books/>
- **Langfuse, Arize Phoenix** — OTEL-compatible LLM observability. → <https://langfuse.com/>, <https://phoenix.arize.com/>

Evaluation

- **RAGAS** — RAG evaluation metrics. → <https://docs.ragas.io/>
- **DeepEval** — LLM eval framework. → <https://docs.confident-ai.com/>
- **TruLens** — evaluation & tracking. → <https://www.trulens.org/>
- **Stanford CRFM — HELM** — holistic evaluation of language models. → <https://crfm.stanford.edu/helm/>
- **OpenAI Evals** → <https://github.com/openai/evals>
- Zheng et al., *Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena* (2023). → <https://arxiv.org/abs/2306.05685>

RAG

- Lewis et al., *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks* (2020). → <https://arxiv.org/abs/2005.11401>
- Vector database & hybrid-retrieval documentation (pgvector, Qdrant, and similar) — treat as configuration.

Guardrails

- **NVIDIA NeMo Guardrails** → <https://github.com/NVIDIA/NeMo-Guardrails>
- **Guardrails AI** → <https://www.guardrailsai.com/>
- **Microsoft Presidio** — PII detection/redaction. → <https://microsoft.github.io/presidio/>
- **Llama Guard** and provider safety classifiers — content safety.

Model gateway & ModelOps

- **LiteLLM** → <https://docs.litellm.ai/>
- **Portkey** → <https://portkey.ai/>
- **Kong AI Gateway** → <https://konghq.com/products/kong-ai-gateway>
- **Cloudflare AI Gateway** → <https://developers.cloudflare.com/ai-gateway/>
- **MLflow Model Registry** → <https://mlflow.org/docs/latest/model-registry.html>

Fine-tuning & model customization

- Hu et al., *LoRA: Low-Rank Adaptation of Large Language Models* (2021). → <https://arxiv.org/abs/2106.09685>
- Dettmers et al., *QLoRA: Efficient Finetuning of Quantized LLMs* (2023). → <https://arxiv.org/abs/2305.14314>
- Rafailov et al., *Direct Preference Optimization* (2023). → <https://arxiv.org/abs/2305.18290>
- **Hugging Face PEFT** → <https://huggingface.co/docs/peft> and **TRL** → <https://huggingface.co/docs/trl>

Platform, IaC & CI/CD

- **The Twelve-Factor App** → <https://12factor.net/>
- **HashiCorp Terraform** docs & recommended practices. → <https://developer.hashicorp.com/terraform>
- **Open Policy Agent (OPA) / Sentinel / Checkov** — policy as code. → <https://www.openpolicyagent.org/>
- **Docker / OCI** image best practices; **distroless** images. → <https://github.com/GoogleContainerTools/distroless>
- **GitHub Actions security hardening** → <https://docs.github.com/actions/security-guides/security-hardening-for-github-actions>
- **StepSecurity Harden-Runner** → <https://github.com/step-security/harden-runner>

Supply chain

- **SLSA** — Supply-chain Levels for Software Artifacts. → <https://slsa.dev/>
- **Sigstore / Cosign** — keyless signing & verification. → <https://www.sigstore.dev/>
- **in-toto** — supply-chain attestations. → <https://in-toto.io/>
- **CycloneDX** SBOM standard → <https://cyclonedx.org/>; **SPDX** → <https://spdx.dev/>
- **Syft / Grype / Trivy** — SBOM & vulnerability scanning. → <https://github.com/anchore/syft>, <https://aquasecurity.github.io/trivy/>
- **CNCF Software Supply Chain Best Practices** → <https://www.cncf.io/>

Progressive delivery & Kubernetes

- **Kubernetes** — Deployments & rolling updates → <https://kubernetes.io/docs/concepts/workloads/controllers/deployment/>
- **Argo Rollouts** (CNCF) — canary/blue-green + analysis. → <https://argoproj.github.io/argo-rollouts/>
- **Flagger** (CNCF/Flux) — progressive-delivery operator. → <https://docs.flagger.app/>
- **Helm** — Kubernetes package manager. → <https://helm.sh/docs/>
- **Kyverno / OPA Gatekeeper** — admission policy (image-signature verification). → <https://kyverno.io/>
- Progressive-delivery patterns — Weaveworks/Flux & Argo communities.

FinOps

- **FinOps Foundation** — **FinOps Framework** → <https://www.finops.org/framework/>
- Provider pricing & prompt-caching documentation — treat as configuration, not fixed facts.

Practitioner literature

- Chip Huyen — *Designing Machine Learning Systems* (O'Reilly, 2022) and *AI Engineering* (O'Reilly, 2024). Production ML & LLM practice.
 - Google Cloud — **MLOps** and **LLMOps** reference architectures & Well-Architected guidance. → <https://cloud.google.com/architecture>
 - Microsoft Azure — **Azure OpenAI / AI** architecture guidance & AI landing zones. → <https://learn.microsoft.com/azure/architecture/>
 - **Team Topologies** (Skelton & Pais) — platform-team organization.
 - **CNCF Platform Engineering** working-group materials.
-

Citation policy & caveats

- **Inline references** throughout the handbook point back to this consolidated list.
- **Versioned facts** (API versions, regulatory deadlines, CVE guidance, pricing) are marked *as of June 2026*. Re-verify against the primary source before production decisions.
- **Not legal advice.** Governance/compliance sections summarize obligations to help you prepare; engage qualified legal/compliance counsel for classification and conformity decisions.
- **Tooling neutrality.** Named tools are representative, not endorsements; the practices are tool-agnostic and portable.

Practice. When a decision depends on a standard or regulation, cite the **primary source** (linked above) in your design docs — not this handbook — so reviewers and auditors trace to authority directly.